41. mTLS and Service Identity Intro

41. mTLS and Service Identity Intro

Phase: Phase 5 — HTTP, TLS, and APIs
Estimated time: 1–2 days
Slug: `41-tls-mtls`

Learning objectives

- Explain client certificates
- Contrast mTLS vs token auth
- Inspect cert fields for clients
- Know mesh (Istio/Linkerd) uses mTLS

Prerequisites

Complete prior lessons. Prefer a Linux VM for `ip`/`ss`/`nft` examples; macOS works for many `curl`/`dig` drills.

```
# Server requesting client cert will fail without key/cert
curl -v --cert client.pem --key client-key.pem https://mtls.example.lab/ || true
openssl x509 -in client.pem -noout -subject -dates
```

mTLS authenticates both sides at TLS layer — powerful inside private service meshes.

Common mistakes

- Long-lived client certs without rotation
- Skipping revocation strategy
- Mixing mTLS and permissive plaintext elsewhere

Exercises

Work in `exercises/41-tls-mtls/`:

```
./test.sh
```

- **A:** make tests pass
- **B:** run 2–3 real commands from this lesson in your lab and note outputs
- **C:** rewrite answers from memory next day

Do not open `solutions/41-tls-mtls/` until after an honest attempt.

Self-check

1. mTLS means?
2. curl flags for client cert?
3. Mesh relation?

Further reading

- https://www.rfc-editor.org/rfc/rfc8446